

Letter to Computers & Security Editor & Reviewers

February 13, 2022

Ms. Ref. No.: COSE-D-22-01279

Title: Testing SOAR Tools in Use

Journal: Computers & Security

Dear Editor in Chief and Reviewers,

Thank you for handling our paper and to the reviewers for the many detailed and constructive comments. The letter accompanying our decision notification requested minor edits with detailed outline of changes and/or responses to the reviewers. Below I have itemized each reviewer's comments with our response and corresponding changes.

On behalf of the authors, thank you for the opportunity to polish this document. We look forward to a hopefully positive decision pending the next review.

Sincerely,

Robert A. Bridges, PhD

Oak Ridge National Laboratory

Per Comment Responses

Reviewer 1: The data collected from the experiments is made available, but it is unclear how it contributes to future research. The test environment, participants, and experiment

parameters are so specific that it would not be worthwhile to replicate. The generalizability of the results is limited. I suggest that claims here be limited to transparency and validation.

We agree and have rewritten our Contributions subsection to mention the dataset but not claim it as a contribution.

Reviewer 1: What are the threats to validity? There are no discussions about this aspect in the paper.

Reviewer 4: This paper has multiple limitations (some intrinsic, others not) and threats to validity, thus they must be acknowledged. I understand the paper contribution even with them, this is the best SOC simulation I have ever seen, but it does not change the fact that the work is not 100% representative of the long-term operation of a established SOC. Please, ack limitations and you will have a good case study paper.

Reviewer 4: Discussion. It acks some limitations, but there is so many more to be acknowledged.

- First, there are intrinsic limitations: A limited number of analysts is used, which is a natural limitation of human research subjects.

- Second, experimental limitations: such as analysts knowing what to look for in a future round since the nature of the tests was the same.

We have now extended the Limitations subsection (in Discussion Section 7) and broken it into two subsections, Experimental Limitations and Intrinsic Limitations. Concisely, the new additions to the limitations are as follows:

Experimental Limitations Added

- analysts knowing what to look for in a future round since the nature of the tests was the same
- training of operators not uniform
- inconsistent tools and number of tools tested by participants
- By instructing the participant to investigate a particular file we limit the study and bias the participant. We included the suggestion provided by the reviewers in the

paper that “A much more robust experiment would be to provide analysts with a set of files and count how many were analyzed as a proxy for how much the SOAR helps. Acknowledge it in the limitations.”

Intrinsic Limitations Added

- Experimental environment does not have the fidelity of a real SOC deployment
- Experiment is not able to test abilities with a (realistic) long term use of a SOAR tool in a SOC (e.g., tweaking and rounds of reconfiguration of dashboards and playbooks would be expected in a real deployment)
- The six SOAR tools used in this experiment may not be representative
- Nearly all participants are US Naval SOC or NOC operators, which may not be representative of the greater population
- Individual participants may vary in their thoroughness and effort put forth in the study, which may affect results
- Our training procedure cannot guarantee that analysts do not gain ability/efficiency with similar investigations over time.
- Vendor-provided installation may vary in quality depending on individuals involved, and it is unclear if the effort for the test deployment is indicative of their actual efforts for a customer.

Reviewer 1: There is a missing conclusion section

Reviewer 4: The paper ends in the discussion section. I think the usual is to have a conclusion section.

We have added a conclusion section summarizing the study and findings.

Reviewer 1: The presentation of results in the paper relies heavily on color coding and does not work well when printed in grayscale. Also, I don't think the color scheme works for the color-blind.

The only plots that *require* seeing the colors are heatmaps representing correlation and the KDE-related plots. For the heatmaps, we require a divergent color palette because

the sign (+/-) of the values is important. We consulted websites such as <https://colorbrewer2.org/#type=diverging&scheme=RdBu&n=3> for recommended color palettes that are color-blind-friendly. Then we investigated the best color schemes—we viewed our plots built with many different color-blind-friendly palettes using <https://www.color-blindness.com/coblis-color-blindness-simulator/>, a website that allow visualization of our plots under different types of color blindness. The findings are that red-blue palette (what we use for heatmaps) is comparably good to only a few other color schemes and better than all others. No color scheme was robust to greyscale viewing. For the KDE plots, Figures 7 and 15, the previous shades of red and green proved ineffective to some types of color blindness. We have changed these color schemes after testing them in the color blind simulator. In short, for the heatmaps our color schemes are the best we believe we can do, and the KDE plots have been changed. Thank you for pointing this out.

Reviewer 1: The paper relies heavily on long and detailed captions of complex figures/visualization. This hampers readability. I would recommend that detailed findings and observations about the figures be discussed in the context of the main text.

Based on your comment, we have added description to the text. Discussion about figures occurs in both the main text, and with summary in captions alongside figures. We intentionally provided result discussions in the figure and table captions as we believe many readers will indeed regard figures, tables, and read captions although not the main body text.

Reviewer 1: Text on many figures is hard to read.

We have increased the font size to 14 on all heatmaps with the exception of Figure 5, which has limited text that seems easy to read.

Reviewer 2: What existing theories about task and automation explain the results? While the paper presents empirical results, I see a lack of an overall theoretical framework to explain and interpret the results.

We have added a paragraph to the top of Section 3.2 with references to theories that couch our study and results. To summarize, Nyre-Yu's 2021 study of SOC's needs and potential solutions proposed by commercial tools results in the need for an empirical study of SOAR tools. The reasons driving this conclusion are evident in many studies of SOC's and proposed theories of benefits possible by automation. Zonouz 2015 and Islam 2019 identify ingestion and correlation of diverse data feeds into a unified platform as a problem because it leads to too much context switching (a problem identified by much older SOC studies, e.g. Goodall 2004). Automation for assisting in prioritization of data for SOC's is called for by Forte 2017 and Islam 2019 to make the most of the operators' time. Automation of mundane tasks is hypothesized to increase quality of investigations and efficiency of operators according to whitepapers of SOAR vendors. Further, vendor whitepapers and Islam 2019 call for timely sharing of threat intel and collaboration.

Reviewer 4: The paper is hard to follow, with many section and requiring lots of back-and-forths. It has good content, almost all information that a paper should have is there, but usually out of place, making stuff hard to find. Please, carefully revise the paper organization. I suggest authors considering a new structure such as (1). How a SOC works; (2). How to evaluate a SOC; and (3). Results.

We have reorganized the Introduction, and we believe it is much easier to follow. Similarly we have reorganized the Related Works section, according to your comments (and detailed more in our responses) below. Further, we have organized Section 3.2 as the methodology for what data to target and how to collect it in the experiment and mapped this to the research questions in the introduction and corresponding results in Section 6. Finally, for the data analysis (preprocessing, imputation methodology, and analysis) methodology, we have extracted these from the Results section and designated a new section (now 5) housing Quantitative Data Analysis. This also points back to Section 3.2 (what data to collect) and 6 (corresponding results). Thanks for helping us organize this paper.

Reviewer 4: Abstract & Introduction. Ensure to capitalize acronyms when defining them: "Modern security operation centers (SOCs)" -> Security Operation Centers (SOCs)

Reviewer 4: Related Works. Check HPC capitalization in 2.0.2

We have capitalized acronym definitions throughout.

Reviewer 4: Abstract. The abstract is good, but maybe a bit long. Try to be more concise when describing the findings.

We have shortened the original 5 sentence summary of findings in the abstract to a single sentence with a concise list, and also made the first few sentences of the abstract more concise.

Reviewer 4: Introduction: This section would benefit from a figure/diagram illustrating the multiple sources of data and the SIEM integration.

We have added a network diagram with discussion of each data source in Appendix A and discussion in a new addition to the intro providing background on SOC operations (as you suggest below). This complements Figure 5 and serves to both help educate on SOC operations, data feeds, and tools as well as our experimental environment and design.

Reviewer 4: Introduction. In 1.1, it is clear that 24 participants are involved, but it is not clear how many organizations (laboratories, locations, so on) are represented by them.

Reviewer 4. Discussion: The paper mentions that most analysts were from Navy, but other weren't. This is the first time external analysts is mentioned. This is another example on how paper organization must be improved. Please create a clear subsection describing the analyzed subjects and presenting all their information in the same place.

We have made an effort to be more precise when discussing participants and to provide the requested information (4 Navy SOCs, one government lab). See new Section 3.3 where we have consolidated the information on recruitment and participation for our study. We have also fixed the referenced sentence in the Discussion section to now read,

Lastly, we note that 21 of 24 analysts were recruited from US Navy security and/or network professionals, with the remaining 3 coming

from the research organization

Reviewer 4: Related Works. Avoid subjective wording as in "SOAR tools are an exciting technology ..." and prefer more objective evaluations.

We have removed this sentence. Thank you for pointing this out.

Reviewer 4: Related Works. I agree that there is no highly relevant related work, but in excerpts such as "there is no academic literature that proposes and tests experimental frameworks for SOAR tool comparison." authors could complement stating what is the closest works found, to what literature is limited to, so one can have a notion on how close/far the literature is from the practice.

We agree. We have changed the current sentence to now read

Our literature survey reveals no academic literature focused on evaluating SOAR tools ... SOAR tool comparison. Rather, related works include user studies focusing on SOC's (without SOAR tools) that motivate the need for SOAR tools, or develop concepts of, components of, or use cases for SOAR tools, as discussed in this section.

Reviewer 4: Related Work. Even though the related work is based on a previous survey, authors will have to bring some papers from the survey back to this paper. When authors say that "Many articles discuss orchestration and automation for security," authors have to cite the papers to give a reference to the reader. it is weird to state that there are MANY but do not cite any.

Thank you. We have added many citations both from the mentioned survey and also a handful of more recent publications that merit inclusion.

Reviewer 4: Related Work. Check paper organization. The 0 in 2.0.2 indicates there is a subsection without a section.

We had a subsection numbering issue that you identified that have now fixed. Overall, the Related Works was completely reorganized into new sections and subsections.

Reviewer 4: Experimental Design. The problem with the definition in 3.1 is that it is not specific for security. This is not a bad thing per se, but since the S from SOAR comes from Security, I was expecting the authors to position what is the particular challenges of the security domain.

While the first three aspects of our SOAR definition in this paper (section 3.1) are indeed security specific—(1) ingestion of security logs and alert and threat intelligence, (2) correlation and prioritization of data based on attack patterns, (3) automation of alert triage and incident response—your point is well taken, namely that with sufficient configurability, such tools could be programmed to ingest and prioritize any sufficiently structured data and can automate many non security tasks. We added the following:

What makes SOAR tools security-specific is that they natively accept security-related concepts in their data such as IPs, files, hosts, are geared towards organizing information around security-related concepts (e.g., timelines of information for a given host/IP, or prioritization based on risk from a threat intelligence feed) and are designed to assist security operators detect, triage, and remediate threats efficiently.

As an aside, note that arguably the two most popular SIEMs, Elasticsearch and Splunk, are used for many nonsecurity applications. Perhaps SOAR tools will cross boundaries as well? Regardless SOAR automation will need to be configured for the domain and in this application must be security, in fact even SOC specific, to some degree.

Reviewer 4: I liked the evaluated aspects presented in 3.2.x. The major limitation of it is that it seems to assume that the reader aware knows the importance of them. Most readers might not know how frequent events happen, why being fast is important, and so on. Please, give more context The same is true for 3.3. Whereas the steps seems accurate, notice that many readers might not know what are the typical flow of a SOC operation. Consider giving more background, either directly in the section, or creating a background section explaining SOC operations.

We did indeed assume that readers would have familiarity with SOC's and their problems. Based on your comment we have included a new section, 1.3 that provides a gentle overview of SOC's data and tools, regular tasks and procedures, and the problems/hurdles faced to couch why SOAR tools are promising and our study design. We feel this strengthens the paper. Thanks.

We also provide a concise paragraph mapping previous works' calls for automation to our study design section 3.2. This maps the background on SOC's to problems SOAR tools aim to address and our attempt at testing specific aspects theorized to help.

NOTE: Since we moved the quantitative data preprocessing and analysis methodologies to their own subsection, now Section 4, the numbering of all comments referencing section's 4-7 refer to sections 5-8 respectively

Reviewer 4: Experimental Setup. In 4.1, it is not clear how stimulation was performed. It is mentioned that D2U is used, but this should be discussed with a greater level of detail, since this is the key point of the test. Generating legitimate traffic/behavior is hard and understanding how it was done is key to understand how realistic the scenario was. Please clarify as much as possible the volume of data, protocols used, how much traffic and logging we are talking about.

With respect to D2U (the data-driven user emulation tool), we have removed its mention from the document as it was mistakenly included. Originally, we instantiated about many nodes with D2U in our test environment, as we planned to leverage the user emulation capabilities to create ambient (i.e., benign) logs and to provide targets for attacks that could provide malicious logs. It proved easier to manually log into the workstations and perform actions as users to produce the needed logs. Hence, while D2U was technically deployed in the environment, it was not actually in use for this study. We regret this misreporting in the original draft and have fixed it by removing D2U from the description all together.

To address your point about difficulty of producing simulated but realistic traffic data, we note that it is not a very relevant problem for this study. As our study focused on how SOAR tools enable investigations by users, the needed requirement was a diverse set of logs allowing realistic investigations to take place. Unlike creating realistic traffic volume and characteristics, this is a problem of leaving the traces of benign and malicious activity in the many diverse data collection devices on the network that can be

pieced together—analysts needed to be able to find the “breadcrumbs” in a sea of ambient or spurious logs. We included the following quote (in now Section 5) to explain this,

Rather than network traffic, SOAR tools act on events forwarded by the monitored cybersecurity tools. Originally we had designed to simulate user and network activity on the workstations, because we wanted the generated security events of interest to be potentially hidden by other, benign events. With so many network security tools set producing alert and monitoring logs, even with this relatively small network there were more than enough benign network security events for monitoring by the SOC operators. All logs and events were consolidated by the SIEM at approximately 100K recorded events per hour.

Reviewer 4: Experimental Setup. In this same sense, also clarify how malicious events are triggered/simulated.

We have added a few sentences to the appropriate scenario subsubsections (5.6.x) with how the scenarios are triggered. In particular,

To generate an alert initiating an NIDS scenarios, we hosted vulnerable services on the local environment. Suricata was then configured to monitor network traffic interacting with those vulnerable services. Alerts were generated either by exploiting the services, which we deemed as a true positive, or by interacting with the services as intended, resulting in a false positive.

and

A malware event was initiated by triggering an alert. To accomplish this, we hosted our previously selected samples on a web server out of band from the local network. A member of our team then logged into one of the test environments and navigated to the web address where the malware sample was hosted to download the sample. Once downloaded, this caused Endgame to alert, allowing the analyst to proceed through a predefined SOP to determine if the sample was benign, suspicious, or malicious.

Reviewer 4: Experimental Setup. In 4.4, while authors are concerning in making analysts tests uniform, it is not clear if the tested attacks were also uniform/normalized somehow. How can we know that the difficulty of the analysis tasks in each test is compatible? Please, clarify.

We added discussion to address this in the referenced section (now Section 5) and in the Limitations section (7). In short, all variants of a given scenario followed the same SOP, and across user-tool tests (across variants), the types of variants used in each user-tool test were similar in terms of the number of steps required to complete them.

... we designed the scenario variants to combat variation in difficulty. Specifically, each user-tool test involved an “easy” and a “hard” NIDS scenario whereby the analyst did not require / did require reading and processing information in the related CVE. The CVE scenarios were chosen by our technical team from the national database to have similar details available for the operator. The non-CVE scenarios were similarly chosen to be equal in complexity. The example scenario provided to all of the vendors did have a CVE. As a test of the installers' attention to detail, we did not disclose--unless asked during installation--that the tested scenarios may not have CVEs associated with them. Similarly, each user-tool test included two Malware Triage scenarios. While the two

particular Malware Triage scenarios varied among many examples in each user-tool test, the two chosen for each user always involved an investigation of a file to be deemed “malicious” or “benign” (both require identical steps in the SOP) and the second scenario a file to be deemed “suspicious” (this required a few extra steps compared to the malicious and benign determinations).

In terms of “normalizing” the data, this is discussed in what is now Section 4. We have added an example in Section 5 as you suggest:

As an example, for quantitative results, such as time to completion, we normalize for each scenario type (subtracting the minimum, then dividing by maximum minus minimum, which maps the data into the interval $[0,1]$). This allows comparability of the quantitative data from two different types of scenarios that would have otherwise incomparable measurements.

Reviewer 4: Experimental Setup. In 4.5, do authors account the chance of analysts becoming better over time? Maybe by having multiple analysis experiences, repeating the experiments with multiple solutions? Is there any procedure to quantify this bias?

Our design was for the training provided to the operators to be sufficient familiarization with working each scenarios. We did not include steps to verify or provide some guarantees of this. We have listed this as a limitation.

Reviewer 4: Results. Sections such as 5.1 lack qualitative analysis. A key question here is: what led analysts to assign a poor score to an installation? What are the installation challenges?

We have provided more information (now moved to Section 3.2.1 based on your comments for reorganization). Concisely, the description of how we administered the installation was moved from the abstract to this section (vendors were given all needed info and instructions 13 days before install week and a week to iterate with a two person

research team). In each of the three categories (integration with data sources, automated ticketing functionality, and playbook functionality) feedback from the two-person install team, originally documented in a survey during the week of install, was processed into a trichotomy from bad to good, -1, 0, 1. Those tools that provided good integration/functionality within the allotted week with relatively little effort received a 1 = good rating, while those that could not deliver working functionality even with ample effort from the install team by the end of their install week received a -1.

As for challenges, we have included the following new paragraph,

From the vendors' point of view, installation is a combination of technical and design challenges. Each SOAR tool has a different setup for display of data, playbook interaction, and automated-plus-manual ticket completion. The vendors needed to design an interactive environment in their SOAR tool platform to facilitate the SOPs for the investigations. The technical challenges are getting these functionalities to work correctly. Technical challenges involve getting unidirectional and sometimes bidirectional functionality with each system in the network required for analysis. Some examples include: automated query from the SOAR tool to the SIEM; submission of a file to ThreatGrid for analysis then receipt of results; submission / query of threat intelligence websites such as NVD, CVE, or VirusTotal and receipt of results. Each of the integrations, when used in an investigation, would then possibly need to trigger a next-step automation based on results and provide appropriate displays.

Reviewer 4: Results. Information omitted from the paper such as in 5.2.3 could be used as a motivation of the paper. A graph showing the variation could be used in the beginning of the paper to claim that network stability is important.

We have added the following sentence,

In addition, the extent to which SOAR tool adoption increases dependence on dependable internet is an open question...

We are not allowed to provide full measurements details from the tools in this regard as a result of our anonymity constraint.

Reviewer 4: Results. In 5.3, the analysts must be better described, since the whole representativity of the paper relies upon them. Please characterize the analysts regarding their background and years of expertise.

In 5.3, can you clarify more the IRB process? Is there a number associated to your review that can be put in the paper for future reference? Did the analysts signed an informed consent form?

Please see Section 3.3 where we have added details on the demographics of our participants. Specifically,

...participants had a mean $\pm$ one standard deviation of $\pm 5.14 \pm 5.82$ years of experience, with a minimum of five months and a maximum of 21 years of experience.

and

This user study received Institutional Review Board (IRB) approval (Oak Ridge Sitewide IRB00000547; submission ID ORAU000785; title Evaluations of Tools that Enhance Security Operations Center Effectiveness) and was determined to be “Exempt human subjects research”. Written consent was not required by participants but did require informed consent indicated by their level of participation. I.e., we provided participants with an information sheet detailing the nature of the research and their rights prior to their agreement to

join the study. Participants could opt out of any/all parts of the experiment.

Reviewer 4: Results. Figure 3 shows that a coding strategy was used, which is adequate. However, we only discover that this was the method used in this part of the paper. For clarity, it would have been better if it had been introduced before. This is why I suggested authors first briefly introducing the methodology and later delving in details.

Similarly, authors could have introduced in the beginning that qualitative and quantitative aspects would be evaluated and separately.

In 5.5.1 we discover that there is a mechanism to count windows swaps. This is interesting, but this is a methodological procedure described in a section that was supposed to be dedicated to data analysis.

The technical procedures of using Likert scale and correlating data sound correct, but the paper organization complicates the overall understanding. It would be better if the paper positioned each (sub)section in terms of the research question it aims to answer (many of them posed in the Introduction)

Thank you for the specific pointers on what was confusing about our previous placement of methodological choices in the paper. Based on your comments we have made many changes.

First, we reorganized the research questions that appear in the Introduction to match the introduction of what SOAR characteristics we target testing in Section 3.2. Each subsubsection of 3.2 introduces a SOAR capability we wish to investigate and a method to collect data for the investigation. We point back to the questions in the introduction when we do this, and for those data types that admit direct analysis, 3.2 also points to the corresponding results subsections (in section 6). (So 3.2 is the methodology used for collecting data, and 6 is the results). Further, for quantitative data collected, the methods of preprocessing and analysis merit their own section (now section 5. Quantitative Data Preprocessing & Analysis Methodologies). In short, we have moved any data collection and methodological discussion from the previous results section (previously section 5) to the data collection design section (3.2) and the new section 5.

Reviewer 4: Results. In 5.6 there is a breakdown per tool. We then notice that the six tools were never clearly introduced in the paper. Their names is not clearly mentioned. The criteria for selecting them was not mentioned as well. Please, make things clearer.

Thanks for the comment, as we did not realize this was unclear. It was stated in the introduction, and we have attempted to clarify that paragraph a bit. It now reads,

This work details the first scientific evaluation and user study of many commercial SOAR tools as the final phase of the third Artificial Intelligence Applications to Autonomous Cybersecurity (AI ATAC 3) Challenge \cite{aiatac3}. The AI ATAC 3 Challenge was funded by the US Navy and it awarded \text{\\$750K} to the winning SOAR tool. AI ATAC 3 was administered to entice the best SOAR tool creators to submit their technology to the competition with the goal of evaluating their benefits and informing potential acquisition decisions for adoption into Navy SOCs. In the first phase, Navy security professionals rated and ranked the eligible submissions based on video overviews of the SOAR tools. All but the lowest-rated tools were advanced to the hands-on testing (i.e., final) round. This down-selection subexperiment is described in detail in our previous work by Norem et al. \cite{norem2021mathematical} and an overview resides in Appendix \ref{sec:appendix-phase1}. This paper describes the final, second phase, a hands-on user study and its results. Only SOAR tools submitted to the challenge and passing the first round downselection were included in the study described in this paper. As required by the AI ATAC Challenges, SOAR tool contenders involved in this evaluation must be held anonymous.

Further, we have reiterated the process of submission and selection in the introduction to Section 3,

As mentioned in the introduction, this user study was the second phase of the AI ATAC 3 Competition, in which the US Navy solicited SOAR tool submissions to be evaluated. All submissions must remain anonymous as a constraint of the competition. Those submissions that were deemed a SOAR tool, as defined below in this section, were considered eligible and underwent a first phase downselection process based on Navy SOC operators rating and ranking video overviews of the submissions---see Appendix B and our previous work \cite{norem2021mathematical}. After phase one, six SOAR tools were selected for evaluation in the user study described in this section. To design a framework ...